



SISW SaaS ISMS Policy Searchable Page

SISW Information Security Topic-Specific Policies

This is a single page version of the SISW Policies contained within the ISMS. This page is meant to quickly reference requirements and updates in an easy to read format and is not the authoritative source for the policies themselves. Authoritative sources may be found as individual files within the link provided

here: https://siemensnam.sharepoint.com/teams/disw_ISMS/Policies/Forms/AllItems.aspx

All additions and updates, driven by ISO/IEC 27001:2022, NIST 800-171 and NIST 800-218, in the policies below are reflected in **red (last updated on 29 January 2025)**.

CTRL + F (Windows shortcut) is the optimal search method to look through this page

SISW SaaS Access Control Policy requirements

1.1. Processes for assignment of access rights, including privileged access rights to information resources must be established.

- 1.1.1. The process and its documentation for assigning access rights must be defined, documented, and reviewed annually and/or when there are changes to the process.
- 1.1.2. A formal user registration and deregistration procedure must be established, using unique user IDs that make it possible for users to be linked to, and made responsible for, their actions.
- 1.1.3. Records of account creation and access approval must be retained for all accounts.
- 1.1.4. User access to information resources must be assigned on a need-to-know basis.
- 1.1.5. Default user privileges and administrative access must be granted based on the requirements of their job or function.
- 1.1.6. Service accounts and shared user accounts shall have an assigned person who holds overall responsibility and a record of users who are authorized to use the account.
- 1.1.7. An approval must be obtained from the information resource owner/admin and documented prior to granting access; moreover, this approval process must account for user credentials as well as service or non-interactive credentials.
- 1.1.8. Information resource owner must establish access criteria based on asset criticality, per the Data Classification, Handling, and Sharing Policy, and considering SISW's Information Security Policy and information security objectives.
- 1.1.9. Use of system utilities and secrets must be limited to the minimum practical number of trusted, authorized users.
- 1.1.10. Any access to information resources or assets should implement security measures when personnel gaining such access are working remotely for the purposes of protecting information accessed, processed, or stored outside SISW's premises.
- 1.1.11. Where possible, data masking techniques must be considered to protect access to sensitive information.

1.2. Assignment of access rights, including privileged access rights to in-scope ISMS applications, systems, data, related infrastructure and supporting tools is based on authorization.

- 1.2.1. The process for assigning access rights to applications, systems, data, related infrastructure and supporting tools is defined, documented, and reviewed annually and/or when there are changes to the process.
- 1.2.2. An approval must be obtained and documented prior to granting access to applications, systems, data, related infrastructure and supporting tools.
- 1.2.3. Upon termination, application, systems, data, related infrastructure and supporting tool access must be disabled.
- 1.2.4. Management must perform a review of access rights to sensitive applications, systems, data, related infrastructure and supporting tools to ensure access appropriateness on a periodic basis.

1.3. Authentication mechanisms are implemented and enforced.

- 1.3.1. Authentication mechanisms such as username/password, certificate, or token must be required to validate a user's, process's, or device's identity before granting access to SISW SaaS information resources.
- 1.3.2. Unique user IDs must be established for each user.
- 1.3.3. IDs, regardless of type, must make it possible for users, devices, or processes acting on behalf of users or devices, to be linked to, and made responsible for, their actions.
- 1.3.4. Unique identifiers must be disabled after a defined period of inactivity, as defined by the team implementing the system.
- 1.3.5. System identifiers must be disabled when removed from service.
- 1.3.6. Unique user IDs cannot be re-used for a certain number of days after they are disabled, as defined by the implementing team, and until the identifier refers to a unique entity.
- 1.3.7. Password requirements must be established for access to SISW SaaS information resources, including requirements related to complexity, lockout, and password reset.
- 1.3.8. Multi-factor authentication must be implemented based upon the criticality of SISW SaaS information resources.
 - 1.3.8.1. MFA is mandatory for privileged accounts and remote access.
- 1.3.9. Unsuccessful logon attempts must be limited.
- 1.3.10. Sessions must be locked or terminated after a period of inactivity and after any other defined termination conditions.
 - 1.3.10.1. Conditions must be determined for ending sessions of access, including terminating the session and an inactivity lockout timer.
- 1.3.11. Accounts inactive for a maximum period of 180 days must be disabled after verification unless specified and approved otherwise.
- 1.3.12. A user notification must be displayed for all systems.
- 1.3.13. Authentication feedback must be obscured during authentication.
- 1.3.14. Remote access must only be permissible through VPN or other methods approved prior to authentication.
- 1.3.15. Replay resistance mechanisms must be in place for authentication with any systems or applications.

1.4 Access to information resources must be reviewed on a periodic basis.

- 1.4.1. Review of access rights must be documented and performed at least at an interval of every 6 months by management or authorized representative to ensure that all initial and continual access provisioned to information resources, assets, and physical locations is appropriate and based on an approved authorization.

1.5 Modification of access rights, including privileged access rights to information resources is based on changes to employment status (e.g. role changes, transfers).

- 1.5.1. The process for disabling of inactive or unauthorized accounts must be defined, documented and logged.
- 1.5.2. Upon termination, access must be disabled within one business day unless formally specified and approved differently.
- 1.5.3. Procedures must be established for access modification (upon role or privilege change) within a defined time period.
- 1.5.4. Access modifications must be performed appropriately upon transfer or change of roles and responsibilities.
- 1.5.5. All credentials, such as passwords, tokens, and keys, shall be changed, disabled, or deleted upon termination or transfer, including accounts out of SISW's control, such as a web portal from a third-party supplier.

SISW SaaS Business Continuity Management Policy requirements

1.1 Processes must be implemented, and requirements must be established for information security and the continuity of information security management in adverse situations.

- 1.1.1. Documented plans, response and continuity requirements must be developed and approved, detailing how SISW SaaS will manage a disruptive event and will maintain its information security to a

predetermined level, based on information security continuity objectives.

1.1.2. Key individuals must be identified, and an adequate management structure must be in place to prepare for, mitigate and respond to a disruptive event using personnel with the necessary authority, experience and competence.

1.1.3. Responsibility must be assigned for providing guidance for Business Continuity Plan (BCP) development, maintenance, and testing and for providing and maintaining a solution for centralized plan retention.

1.1.4. Business impact analysis (BIA) shall be performed to identify critical systems assets, and information communication technology (ICT) to determine continuity requirements, RTO (recovery time objectives) and RPO (recovery point objectives) where expectations and strategies are established for all disruption stages.

1.1.5. Notifications of any material changes must be sent to all applicable functions and partners.

1.1.6. Functional units to whom this policy applies must be briefed at least annually to ensure their understanding of BCP requirements.

1.2 Processes, requirements, and controls must be documented, implemented, and maintained to ensure the required level of continuity for information security during an adverse situation.

1.2.1. A unified framework for BCP must be maintained to ensure the consistency and accuracy of the plans/process between functions.

1.2.2. Critical business functions must be identified and analyzed for the impact of their loss or interruption.

1.2.3. Priorities for recovery of specific functions and support systems must be determined.

1.2.4. BCP capabilities must be adequately resourced to deliver key planning, maintenance, exercising, and reporting activities.

1.2.5. Backup and restoration measures for information, systems and services must be established and regularly tested.

1.3 Requirements must be implemented to ensure information security continuity controls are verified at regular intervals to assess their validity and effectiveness during adverse situations.

1.3.1. BCP/DR must be exercised at least once every 12 months or when significant changes occur. The tests may include planned outages, live exercises or walkthroughs/tabletop discussions.

1.3.2. BCP/DR test cases must be documented. Expected outcomes (e.g. a runbook) must be included in the documentation.

1.3.3. The results of the execution of BCP/DR test cases including who participated in the testing exercise, details of the results obtained and any unexpected outcomes must be retained.

1.3.4. Deficiencies discovered during testing must be remediated through the change management process.

1.3.5. Planned testing must take place within a scheduled timeframe to avoid any disruption to SISW SaaS information resources.

1.3.6. The BCP must be evaluated for reasonability against contractual, legal, environmental, and business requirements.

1.4 Administrative and technical controls must be implemented at information processing and corporate facilities with redundancy commensurate to meet availability requirements.

1.5 SISW must implement capacity monitoring mechanisms for information resources to ensure the appropriate level of capacity is met.

1.5.1. SISW must consider reviewing capacity requirements periodically taking into account projections of future capacity requirements and trends.

1.5.2. Where possible, SISW should conduct stress tests on all systems and services to ensure the appropriate level of capacity is available to meet peak performance requirements.

1.5.3. For any critical systems identified by SISW, plans regarding capacity management must be documented.

SISW SaaS Change Management Policy requirements

1.1 Change management processes must be established to facilitate change planning, prioritization, review, approval, testing, implementation, and monitoring.

- 1.1.1. The process for change management must be defined, documented, and reviewed annually and/or when there are changes to the process.
- 1.1.2. Prior to implementation, changes must be:
 - Documented to include description, scope, implementation steps, acceptance criteria, dependencies, validation plans, and roll back or roll forward plans
 - Assigned ownership
 - Prioritized
 - Independently reviewed (e.g., peer review)
 - Tested (e.g., unit, functional, integration, performance, and security testing)
 - Approved or rejected
 - Communicated to relevant interested parties
- 1.1.2.1. The progress of execution of each change must be documented within a change ticket
- 1.1.2.2. Where one ticket is used for multiple changes, the progress of each change must be clearly documented
- 1.1.3. Emergency change management processes must be established and implemented.
- 1.1.4. Roll back or roll forward processes must be established, including responsibilities for aborting, and recovering from unsuccessful changes and/or unforeseen events.
- 1.1.5. Changes must be monitored during and after implementation according to established deployment criteria.
- 1.1.6. Roles and responsibilities for change management activities, including consideration of segregation of duties, must be established.
- 1.1.7. Ensure documentation standards (e.g. operational, user, continuity plan) are applied to any updates/changes as governed by the document management system for each particular record (such as Wiki, Confluence, etc.).

SISW SaaS Cryptography Policy requirements

1.1 Encryption methods should be leveraged to protect data at rest, or data in-transit when possible.

1.2 Data at rest should be encrypted using symmetric key encryption methods such as AES, with key strength set to a minimum 128-bit length to ensure best protection.

- 1.2.1. Hardware based technologies should be leveraged where possible, and in conjunction with any software/OS based encryption as a second layer of protection for data at rest.
- 1.2.2. Where possible, software based encryption should be enabled by default on both fixed media and removable media, where hardware based encryption might not be feasible.
- 1.2.3. Encryption keys and passwords associated with symmetric key encryption should not be stored in plain text format. Password vaults should be leveraged, with full audit trail functionality to capture access/modification activity at a user level.

1.3 Data in-transit should leverage end to end encryption, and encryption at multiple layers (Application, Transport, Network etc.) should be enabled to offer maximum protection.

- 1.3.1. Asymmetric encryption, when in service, should leverage a minimum key strength of 2048 bits, and must use a strong hashing algorithm such as SHA-2 256 or greater.
- 1.3.2. Secret keys shall not be available in plain text and shall be stored and transmitted encrypted using a strong password or wrapping key technique.
 - 1.3.2.1. Secure Key Management Systems (KMS) shall be used to store secret keys in the cloud
- 1.3.3. SSL/TLS certificates should be rotated on a regular basis, and a certificate used for public facing services should not be used for more than a 2- year period.
 - 1.3.3.1. TLS protocol version 1.2 or higher must be used.
 - 1.3.3.2. The use of SSL 1.0, SSL 2.0, SSL 3.0, TLS 1.0, and TLS 1.1 is not allowed.
- 1.3.4. Wild card certificates will not be used on any Cloud Accounts and Public Facing Services and should be used sparingly for private/internal services to encourage best practices.
- 1.3.5. Self-signed certificates may only be used with prior review and approval by DI SW Cybersecurity Officer

- 1.3.6. Certificates from only the Siemens Server Registration Authority (ServerRA) AWS, QuoVadis, Digicert or Let's Encrypt shall be used for Cloud Webserver accessible from the internet.
- 1.3.7. Certificate providers following the WebTrust Principles and Criteria for Certification Authorities may only be used temporarily with prior review and approval by DI SW Cybersecurity Officer
- 1.3.8. In addition to key based security, the organization will also review strength of cipher suites compatible with TLS endpoints, and will enable/disable on an as needed basis.

1.4 All private communication tunnels (such as VPN) established between production network and remote networks should leverage IPsec, or an industry standard equivalent.

- 1.4.1. Individual IPsec tunnels should leverage independent pre-shared keys, and keys should not be reused.
- 1.4.2. IPsec pre-shared keys should not be stored in plain text format. Password vaults should be leveraged, with full audit trail functionality to capture access/modification activity at a user level.

1.5. Generation of keys, tokens, passphrases shall follow the applicable vendor or service recommended best practices, or shall conform to the requirements below absent any recommendations

- 1.5.1. Each instance of key, token or certificate shall be generated using a unique input or seeding value; where possible a random seeding key shall be applied using a random number/key generator application or program
 - 1.5.1.1. Where applicable, the random seeding key shall be deleted irretrievably. Where a recovery process is necessary and the seeding key should be preserved, a secured keystore or vault shall be used for the purposes of storing the key and access controls applied, conforming to the SISW SaaS Access Control policy.
 - 1.5.1.2. The storage of seeding keys in unencrypted formats on endpoints is strictly prohibited, and the storage of seeding keys as images of QR codes is also strictly prohibited.
- 1.5.2. Where key strength, cipher and hashing techniques for the purposes of generation of private and public keys is customizable, industry best practices and recommendations shall be followed.
- 1.5.3. When generating keys, if an expiration attribute is customizable, the lifetime of such secrets/keys shall follow the policies within table 1 of this document

1.6. Storage of private keys, tokens and passphrases shall be secured, vaulted using access control mechanisms as recommended within the SISW SaaS Access Control Policy

- 1.6.1. Where practicable, SISW owned and operated key vaults shall be leveraged for purposes of storing secrets
- 1.6.2. A secure vault or KMS shall be the primary storage mechanism for keys, tokens and passphrases, and the storage of such keys on any endpoints, scripts, code or other human readable format is strictly prohibited.
 - 1.6.2.1. If necessary to host a secret/private key on an endpoint, applicable security mechanisms from within this policy shall be enforced on such systems. For example, storage of private keys on a server shall be possible only if the private key file is encrypted via a secret, and disk encryption has been applied.
 - 1.6.2.2. Where necessary, a key encrypting key or wrapping key shall be applied for the protection of highly critical secrets.
- 1.6.3. Access to the storage location shall be moderated by SISW approved identity and access management services, and a full audit trail shall be available to ensure both admin and user actions on such secrets are recorded.
- 1.6.4. The copying of secrets out of vaults shall be technically restricted where possible. Logging and monitoring for such efforts shall be applied in accordance with the SISW SaaS Logging and Monitoring policy
- 1.6.5. Access reviews of the key storage vaults shall be performed regularly, in accordance with the SISW SaaS Access Control Policy.

1.7. Where possible, the use of static certificates, keys, tokens and passphrases as authentication/authorization credentials should be a secondary mechanism, and not deployed as the primary identification factor

1.8. Static Keys, token, passphrases shall be securely disposed at the conclusion of the use case or end of life, and shall not be reused

- 1.8.1. Keys, tokens and passphrases stored in key vaults shall be deleted/removed using applicable vault mechanisms.
- 1.8.2. Key attributes and seeding keys used to generate secrets shall also be disposed when the key/secret is disposed.

1.8.3. Where keys, token or secrets have been stored in endpoints or assets independent of the key vault, a secure wipe procedure shall be applied to remove such keys

1.9. Keys, tokens, passphrases shall follow the schedule within Table 1 of this document for retirement/rotation, or after the detection of a security incident that may have led to the compromise of such secrets

Please refer to the policy document to view Table 1.

SISW SaaS Data Backup and Recovery Policy requirements

1.1 Siemens has assigned levels for data classification, and all data backed up must be subject to same classification level as was the data source.

1.1.1. Data backed up will be handled as per the requirements associated with the data classification level, as detailed in the Siemens Industry Software (SISW) SaaS Data Classification, Handling and Sharing Policy.

1.2 Data backup methodology used must preserve data structure as found in the source, with clear labeling of source of data, and location hierarchy as found in the source.

1.2.1. Data scope for the backup must be defined by considering the respective environment which can include configuration data, license files, and contractual requirements

1.3 Data backup schedules must leverage incremental, daily and weekly/monthly rollup routines to optimize recovery point objective (RPO) and storage efficiencies.

1.4 Data backed up should be stored in a location isolated from the source, minimally at a logical level.

1.5 Data backup routines must generate an activity log, and the log information should be reviewed on a regular basis to verify job status. Backup logs are subject to policies set forth in the Siemens Industry Software (SISW) SaaS Secure Logging and Monitoring Policy.

1.6 Data backed up must be replicated to an offsite location or alternate Cloud availability zone based on data criticality and classification. Offsite replication must also be logged and reviewed to ensure job completion.

1.7 Data backed up must be tested via restore tests on a regular basis. The tests must be conducted to verify data availability and integrity to ensure any recovery point objective (RPO) and recovery time objective (RTO) requirements.

1.1.1. Data restore activity must be logged, subject to policies set forth in the Siemens Industry Software (SISW) SaaS Secure Logging and Monitoring Policy.

1.1.2. Data restore activity must include data backup restore tests that are inclusive of information, software, and systems.

SISW SaaS Data Classification, Handling, and Sharing Policy requirements

1.1 Data classification levels must be documented and implemented based on established criteria.

1.1.1. Data classification levels must be defined in consideration of the following impacts, should the data be inappropriately disclosed:

- Regulatory, legal, and contractual liabilities
- Financial liabilities
- Operational impacts
- Damages to reputation or public image
- Potential physical harms

1.1.2. Data sets containing data from multiple classification levels must be classified at the level of the most sensitive data type within the data set.

1.1.3. SISW SaaS data must be classified according to the Siemens Data Classification Acceptable Use Document, which allocates the following classification levels.

Strictly Confidential: This applies to corporate proprietary information, for which unwanted disclosure can have "major" risk impact e.g. for an Operating Company (see ERM scale). This is information that is

crucial for the success and survival of the entire company or parts of it. Disclosure can cause very serious harm to business interests and goals of the company, lead to grave legal consequences, impinge on the value of Siemens stock or severely damage the company's reputation (e.g. company or sales strategy papers, economic and budget plans, information on merger and acquisition topics). This information should be distributed on a need-to-know basis and requires a non-disclosure agreement for sharing with people outside the company.

Confidential: This applies to corporate proprietary information, for which unwanted disclosure can have "moderate" or "significant" risk impact e.g. for an Operating Company (see ERM scale). The information can be valuable for competitors (e.g. controlling data, procurement and sales contracts, source code of software developed by SISW SaaS or design documents). This information should be distributed on a need-to-know basis and requires a non-disclosure agreement for sharing with people outside the company.

Restricted: This applies to corporate proprietary information, for which unwanted disclosure can have only "marginal" or "minor" risk impact for e.g. an Operating Company (see ERM scale). This information may be accessible for a large circle of employees on need-to-know basis, but not generally available to people outside the company (e.g. organizational plans, internal telephone directories, internal guidelines, test reports, etc.). This information may be distributed externally on a need-to-know basis after the external parties are informed about their obligations. Consider a non-disclosure agreement when sharing with people outside the company.

Unrestricted: This kind of classification applies to corporate information, which is intended for public use or where disclosure has no negative impact to Siemens (e.g. press releases, job postings, official price lists, advertising materials, etc.). It is either labelled as "unrestricted" or immediately identifiable as for public-use information (e.g. an internet web site).

- 1.1.4. All data stored on the cloud is classified as **Confidential** by definition. As such, there is no need for tagging or other marking.
- 1.1.5. All source code and software design documentation is classified as **Confidential** by definition. As such, when these artifacts are stored within a controlled system (e.g. GitLab, Polarion, Jira, etc.) there is no need for further tagging or other marking.
- 1.1.6. All Controlled Unclassified Information (CUI) referenced in NIST 800-171 is classified as **Confidential** by definition.

1.2 Data handling and sharing requirements must be documented and implemented based on established criteria.

- 1.2.1. Data handling requirements must be defined for:
 - 1.2.1.1. Data stored within SISW SaaS information resources (e.g., databases, servers, workstations, mobile devices, etc.) and environments of Third-Party Providers
 - 1.2.1.2. The classification of an asset shall follow the classification of the most sensitive classified data within that asset
 - 1.2.1.3. Data transmitted across production, corporate, and public networks
- 1.2.2. Requirements must be established for sharing data with authorized internal and external entities.
- 1.2.3. SISW SaaS data must be handled and shared according to the Siemens AG Cybersecurity Card – Protection of Sensitive Data.
- 1.2.4. Users shall either manually activate the "lock screen" or logout before leaving a system unattended.
- 1.2.5. A non-disclosure agreement must be executed in accordance with the rules defined in 1.1.3 when sharing information outside the company.
- 1.2.6. The requirements for data and resource handling, according to their security classification and Acceptable Use within the SISW Company Directives, apply regardless of location.
- 1.2.7. Mechanisms shall be implemented to conceal sensitive information such as PII by means of, including but not limited to, data masking, pseudonymization, and anonymization in accordance with the established classification criteria.
- 1.2.8. Measures regarding data leakage prevention shall be implemented across all data classified as Strictly Confidential, Confidential and Restricted.
- 1.2.9. Data retention periods shall be established and documented with consideration to legal and regulatory requirements in accordance with the established classification criteria.

1.2.10. Information shall be deleted when no longer needed in accordance with the defined retention periods with considerations to:

- Using approved secure disposal services
- Deleting old versions and temporary files

1.2.11. Using an approved deletion software to ensure deleted information cannot be recovered

SISW SaaS Incident Management Policy requirements

1.1 Information security threat intelligence data must be continually obtained and evaluated.

1.1.1. Contacts with authorities, external interest groups, or forums that handle issues related to incidents must be maintained.

1.1.2. SISW must determine internal resources that are assigned responsibilities with regards to receiving, analyzing, and prioritizing the response to security threats and risks to the organization.

1.2 Processes for SISW personnel and external entities to report incidents must be established. **Please refer to the policy document to view the Incident Response Steps flowchart.**

1.2.1. Employees/contractors must immediately report all potential incidents.

1.2.2. SISW CISO and/or DI IT ISO shall be informed and involved based on the severity of the security incident.

1.2.3. Potential incidents must be recorded by applying the corresponding tool.

1.2.4. The validity of reported incidents must be evaluated according to established incident classification criteria.

1.2.5. In the event of a potential incident involving PII (Personally Identifiable Information), the SISW Data Privacy Officer shall be involved.

1.3 An incident response and remediation plan must be established, implemented, reviewed, and tested.

1.3.1. An incident response plan must be established to formalize processes for classifying, escalating, detecting, analyzing, containing, eradicating, recovering from, and reporting incidents.

1.3.2. A communications model must be established to ensure the timely exchange of information related to incidents.

1.3.3. Response activities and observations must be documented in accordance with established criteria based on incident severity ratings.

1.3.4. Procedures for handling forensic evidence must be established and account for:

- Chain of custody
- Integrity and storage of evidence

1.3.5. Post-mortems of critical and high severity incidents as well as events that were not initially classified as incidents (i.e., false negatives) must be performed.

1.3.6. The incident response plan must be reviewed and tested at least annually.

1.4 A remediation plan must be executed before incident closure.

1.4.1. The remediation steps must be documented.

1.4.2. The incident closure must be communicated.

1.4.3. Lessons learned must be executed with the intention to identify and amend incident process gaps and eliminate incident causes.

1.5 Core and extended members of the Computer Security Incident Response Team must be trained upon onboarding and periodically thereafter.

1.5.1. The incident response plan must be shared with personnel as a component of the Incident Response team onboarding process.

1.5.2. Periodic trainings (e.g., tabletop exercises) must be performed to refresh the Incident Response team members' knowledge of incident response processes and responsibilities.

SISW SaaS Information Resource Management Policy requirements

1.1 Requirements must be implemented that facilitate the tracking of information resources as part of an asset inventory.

- 1.1.1. Requirements must be in place to facilitate the tracking of information resources onboarding, reuse and disposal as part of an asset inventory system.
- 1.1.2. Loss, theft, or other information security incident related to SISW information resources must be reported immediately based on requirements in the incident management policy.
- 1.1.3. Periodic review of all asset inventories for accuracy, completeness, and to ensure appropriate ownership assignment and tracking.

1.2 Requirements must be implemented that facilitate the definition assignment of ownership of information resources.

- 1.2.1. Standards must be established for the classification, labeling, and handling of information resources based on their classification to protect from unauthorized disclosure or misuse.
- 1.2.2. Requirements must be established for the management of mobile devices.
- 1.2.3. Sensitive data must not be stored on mobile devices without encryption.

1.3 Requirements must be implemented that facilitate the standards for the acceptable use of information resources in accordance an established policy on human resources security.

- 1.3.1. Information resources must be used in accordance with the SISW acceptable use guidelines.
- 1.3.2. Processes must be implemented that facilitate the requirements for the acceptable use of information resources in accordance with an established policy on human resources security.

1.4 Standards must be established for the return of information resources upon termination of employment, contract or agreement.

- 1.4.1. Requirements must be established for the return of information resources upon termination or change of employment, contract or agreement.

1.5 Standards must be established for the classification, labeling, and handling of information resources.

- 1.5.1. Resources must be handled in accordance with their established security classification as defined by the Siemens Industry Software (SISW) SaaS Data Classification, Sharing, and Handling Policy.

1.6 Requirements must be established for the management of removable media in accordance with the classification standards.

- 1.6.1. Processes must be established for removal of sensitive data from information resources before the disposal or reuse.
- 1.6.2. Endpoint device management should take into consideration protection against malware, remote disabling, end user analytics, encryption (see Cryptography Policy), and backup requirements (see Data Backup and Recovery Policy).
- 1.6.3. Endpoint devices should leverage virtual private networks (VPNs) when utilizing unsecure or public networks.
- 1.6.4. Internal wireless networks should be configured with secure protocols.

1.7 Requirements must be implemented to facilitate defining data retention, decommissioning, and disposal protection requirements consistent with contractual, legal, environmental, and business requirements.

- 1.7.1. Information resources decommissioning and disposal methods must be defined based on the information resources criticality.
- 1.7.2. Processes must be implemented to facilitate defining data retention, decommissioning, and disposal protection requirements consistent with contractual, legal, environmental, and business requirements.
- 1.7.3. Prior to reuse or disposal of any asset, SISW must define requirements, inclusive of authorization, to remove or securely overwrite any sensitive information that may be on devices or storage media.

1.8 Processes must be implemented for the management of BYOD devices that access SISW information resources.

1.9 Standards should be established to guide personnel on the types of software installations that are permitted and what types of installations are prohibited on information resources.

1.10 The use of resources shall be monitored, tuned and projections made of future capacity requirements to ensure the required system performance.

1.1 SISW's ISMS has been developed as a system that recognizes the need for organizational compliance with strong security principles, guided by ISO/IEC 27001:2022 requirements.

1.1.1. SISW will recognize and comply with all applicable local legislative, statutory, regulatory requirements in addition to contractual requirements established by interested parties.

1.1.1.1. The central Legal, Data Privacy, and Compliance organizations will review applicable local legislative, statutory, regulatory requirements and contractual requirements to remain current with changing laws and regulations. They will document and issue guidance as required by law supported by the "Privacy by Design" tool and process.

1.1.2. Where applicable, considerations to affected laws and regulations should be taken into account when the organization:

- Conducts business in other countries
- Transfers information over jurisdictional borders
- Uses products and services from other countries

1.1.3. SISW must identify and comply with specific legal requirements regarding cryptography such as the use of cryptography across international borders and the import and export of hardware and software that perform cryptographic functions.

1.1.4. SISW must include information security requirements within contracts with customers, third-party suppliers, and insurance companies.

1.2 SISW purchases and licenses software from a variety of sources. Any duplication of software except as permitted by related license agreements is a violation of copyright law. Installing unauthorized software on a Corporate Environment or Production Environment system can lead to potential system failures, system degradation, or security incidents and data loss, and is therefore strictly restricted per the Employee Manual.

1.3 Software license requirements are communicated to all end users as required.

1.4 SISW must publish procedures for intellectual property rights compliance that includes maintaining appropriate license conditions and the disposal or transfer of software to others.

1.5 SISW recognizes three types of software licenses that may be in use within the ISMS:

- **Subscription based:** This model provides for on-demand mode of licensing and will hence enforce any compliance requirements inherently. Such licenses are not considered SISW property and will be strictly returned to the owner upon termination.
- **Fixed licenses:** Fixed licenses are designed for use with a single asset and may have restricted rules towards reuse and transfer. SISW will abide by all governing acceptable use policies associated with such licenses and users will need to verify with Legal before making copies or reusing software associated with such licenses.
- **Open Source:** Open source software and licenses may be used in the SISW environment and in the production of SISW assets only with the prior approval of Legal. Such licenses are closely monitored by SISW for fair use terms and users will be advised on the appropriate restrictions by SISW management team.

1.6 Procedures shall be documented, and communicated to relevant personnel, regarding the preservation of PII inclusive of defined roles and responsibilities regarding the handling of PII.

1.6.1. SISW must comply with all national and local laws and regulations regarding the preservation of privacy and protection of PII.

1.7 SISW has documented operational standards and procedures and made these available to all employees to serve as a reference for operating within the ISMS.

1.8 SISW employees have designated roles and responsibilities both within the ISMS and their job functions that help guide them on their contribution towards the success of the ISMS.

1.9 SISW provides for adequate training and awareness to its employees on compliance with applicable requirements, and their participation in the effort.

1.10 SISW management recognizes the need for regular independent reviews of the compliance program and will designate an appropriate authority to conduct said reviews on an as needed basis.

1.11 Policy exceptions shall be documented, reviewed, and approved using the exception process within AMT.

1.11.1. Policy exceptions shall only be submitted for review and approval into the AMT tool after review with the Business Segment Leader.

SISW SaaS Information Security Human Resources Policy requirements

1.1 The SISW Human Resources (HR) department is the central resource for employees to interface with the organization and will be the point of contact for any concerns with regards to employment, security, safety and benefits.

1.1.1. SISW collects data required to screen candidates during the recruiting and hiring process, and information required to fulfill the company's HR functions, deliver benefits, process payroll, and enable access to SISW information systems. This information includes, but is not limited to, name, date of birth, address, phone number, social security number, taxpayer identification number, age, marital status, and dependent information. Country specific laws and limitations are taken into account for the screening of new hires.

1.1.2. SISW uses third-party systems as part of the HR function; recruiting, onboarding, payroll, benefits, wellness, and retention. These third-party systems provide secure hosting of SISW data, and SISW retains full rights as the data controller on all these systems.

1.1.3. The SISW HR will make the final determination for employment, and employment may be subject to additional verification or screening processes as determined by HR, and as permitted by applicable law.

1.2 SISW will communicate to employees, all terms and agreements with regards to employment, via HR and employees must acknowledge receipt at the time of employment, and during any subsequent updates, as directed by HR. The contractual obligations may reflect SISW's policies for information security while also emphasizing:

- Employee's requirements to protect and safeguard SISW assets with respect to security, availability, and confidentiality
- Employee's legal responsibilities and rights (e.g., regarding intellectual property, workplace privacy, etc.)
- The corrective action process for remediating violations of SISW's security requirements

1.3 Managers at all levels of the organization shall be engaged in driving security within the organization and shall foster behavior and policy that drive and encourage all employees to apply security in accordance with SISW's established policies and procedures. Managers, at all levels of the organization, shall:

- Serve as role models for their teams, demonstrating support for, and proper compliance with, information security policies, procedures and control
- Ensure that their teams continue to have the appropriate resources, skills and qualifications necessary to complete their work

1.4 SISW HR provides Siemens Business Conduct Guidelines and SISW Company Directives that serve as guidelines for performing work within SISW's systems and must always be observed by all employees. Any SISW assets that may be issued to or used by employees should be used in accordance with these policies and employees must always make reasonable efforts to safeguard the asset.

1.5 SISW provides for adequate training and awareness to all its employees on compliance with applicable requirements, and their participation in the effort. The training shall cover:

- Management's commitment to information security
- The importance of understanding and complying with all applicable information security rules and obligations found in policies, procedures, standards, laws, regulations and contracts
- How to perform any needed role-specific information security duties
- Personal accountability for one's actions/inaction, as well as general responsibilities for securing and protecting information

- Basic procedures (e.g., information security incident reporting and insider threat reporting) and baseline controls (e.g., password requirements, protection from malware, and clear screen/desks)
- Points of contact and other available resources for additional information and advice on information security matters
- Security awareness training must be completed by new employees, current employees, and contractors within a 90 day time period from assignment unless a different schedule is defined by Human Resources.

1.6 SISW HR and the respective manager must assess and resolve disciplinary and non-compliance issues related to SISW information security directives, policies, standards, and procedures. The disciplinary process must be communicated to employees.

1.7 SISW HR is responsible for the overall termination or change of employment process in collaboration with the supervising manager and IT.

- 1.7.1. Procedures must be developed for the removal of access to SISW information resources and physical locations as well as the return of all SISW assets and information upon a change or termination of employment, contract, or agreement.
- 1.7.2. Responsibilities for performing termination or change of employment must be clearly defined, communicated to relevant personnel, and reviewed annually by SISW HR.
- 1.7.3. SISW employees' security requirements that continue after employment must be defined, communicated, and enforced.
- 1.7.4. Access rights removal should be initiated by SISW HR and/or the supervising manager.
- 1.7.5. Information security responsibilities and duties that are to continue for a defined period after an employee's termination or change of employment responsibilities shall be defined and communicated in the employee's terms and conditions of employment and shall be enforced via that contract.

SISW SaaS Information Security Policy requirements

1.1 Access Control

Access will be restricted by access control, user access management, privileged access, access review processes, along with multi-factor authentication and password requirements, where applicable, in accordance with the Siemens Industry Software (SISW) SaaS Access Control Policy.

- 1.1.1. Restriction of access to information resources and their associated functions must be established based on information resource requirements and in accordance with a documented policy on access control. Restriction of access must be extended to data stores or storage mechanisms, and where possible applied on documents or information directly, to reduce opportunities for data exfiltration.
- 1.1.2. User registration and de-registration processes must be established to enable assignment of access rights to information resources based on authorization.
- 1.1.3. Administrative user registration and de-registration processes must be documented and established for privileged access rights.
- 1.1.4. Authentication credentials for management of user and system information resource must be in alignment with industry best practices.
- 1.1.5. User access rights must be reviewed at periodic intervals.
- 1.1.6. Processes for the removal or modification of user and system access rights must be established based on user status changes (termination/modification of employment, contract or agreement) or information resource changes.
- 1.1.7. A separation of roles must exist within the user access management lifecycle.

1.2 Information Security Business Continuity Management

Information security aspects of business continuity must be managed to support the availability of information resources and support capacity management requirements in accordance with the Siemens Industry Software (SISW) SaaS Business Continuity Management Policy.

- 1.2.1 Processes must be implemented, and requirements must be established for information security and the continuity of information security management in adverse situations to support established SLAs or commitments of the organization.
- 1.2.2 Processes, requirements, and controls must be documented, implemented, and maintained to ensure the required level of continuity for information security during an adverse situation.
- 1.2.3 Requirements must be implemented to ensure information security continuity controls are verified at regular intervals to assess their validity and effectiveness during adverse situations.

- 1.2.4 Administrative and technical controls must be implemented at information processing and corporate facilities with redundancy sufficient to meet availability requirements.
- 1.2.5 Capacity monitoring mechanisms for information resources must be implemented to ensure the appropriate level of capacity is maintained, and adequate planning procedures in support of maintaining capacity at all times must be implemented.

1.3 Change Management

Formal change management requirements must be followed when introducing new information resources and making changes to existing information resources in accordance with the Siemens Industry Software (SISW) SaaS Change Management Policy.

- 1.3.1 Formal responsibilities must be implemented to facilitate the control of changes.
- 1.3.2 Documented requirements to facilitate change requests, prioritization, review, approval, testing, and implementation of changes must be in place.
- 1.3.3 Changes must be monitored during and after implementation.

1.4 Compliance

Compliance with security policies, standards, and any other relevant security requirements (i.e. legislative statutory, regulatory, and/or contractual) must be reviewed in accordance with the Siemens Industry Software (SISW) SaaS Information Security Compliance Policy.

- 1.4.1 Processes must be implemented to facilitate the identification, documentation, and maintenance of relevant legislative, statutory, regulatory, contractual requirements, and the organization's approach to meet these requirements.
- 1.4.2 Processes must be implemented to facilitate protection of records from loss, destruction, falsification, unauthorized access, and unauthorized release, in accordance with legislative, statutory, regulatory, contractual, and business requirements.
- 1.4.3 Requirements must be implemented to facilitate the privacy and protection of personally identifiable information as required in relevant legislation, regulation, and contracts.
- 1.4.4 Requirements must be implemented to facilitate the application of cryptographic controls in compliance with all relevant agreements, legislation, and regulations.
- 1.4.5 Processes must be implemented to facilitate independent reviews of the continuing suitability, adequacy, and effectiveness of its approach to managing information security.
- 1.4.6 Processes must be implemented to facilitate periodic area-specific technical and administrative review of the compliance of information processing and requirements with applicable security policies and standards.
- 1.4.7 Policy exceptions shall be documented, reviewed, and approved using the exception process within AMT.
 - 1.4.7.1 Policy exceptions shall only be submitted for review and approval into the AMT tool after review with the Business Segment Leader.

1.5 Data Privacy and Security

Information either generated by, or entrusted to, the care of SISW personnel will be classified with appropriate protections to avoid unauthorized disclosure in accordance with the Siemens Industry Software (SISW) SaaS Data Classification, Handling, and Sharing Policy.

- 1.5.1 Processes must be implemented to ensure information resources are classified according to its legal requirements, value, criticality, and sensitivity to SISW.
- 1.5.2 All Controlled Unclassified Information (CUI) referenced within applicable ISMS documents are classified as Confidential information in accordance with Siemens Corporate Directives.
- 1.5.3 Technical and administrative controls must be implemented to be consistent with information resource classification.
- 1.5.4 Requirements to facilitate consistent handling of information must be implemented according to its legal requirements, value, criticality, and sensitivity.
- 1.5.5 Processes must be implemented to facilitate the information resource lifecycle protection commensurate with the information resource classification.
- 1.5.6 Requirements must be implemented to facilitate handling of media according to its legal requirements, value, criticality, and sensitivity.
- 1.5.7 Requirements must be implemented to facilitate labeling of information resources in accordance with information resource classification guidelines.

- 1.5.8 Requirements must be implemented to facilitate securing of media during transit in accordance with information resource classification guidelines.
- 1.5.9 Processes must be implemented to conceal sensitive information, such as personally identifiable information (PII), from unauthorized SISW employees and contractors.
- 1.5.10 Requirements for data leakage prevention and data retention periods must be defined and implemented according to the established classification criteria.
- 1.5.11 Information resources must be protected through the implementation of cryptographic techniques in accordance with the Siemens Industry Software (SISW) SaaS Cryptography Policy.
 - 1.5.11.1 Processes must be implemented for the creation, review, approval, and communication of an established policy on cryptography.
 - 1.5.11.2 Requirements must be implemented relating to the use, protection, and lifetime of cryptographic keys.
- 1.5.12 Data must be encrypted in accordance with data classification and handling requirements specified in the Siemens Industry Software (SISW) SaaS Data Classification, Handling, and Sharing Policy.
- 1.5.13 Backup practices of critical information resources must be performed, tested, and maintained in accordance with the Siemens Industry Software (SISW) SaaS Data Backup and Recovery Policy.
- 1.5.14 Requirements must be implemented to facilitate effective backup plans which give consideration to accurate and complete records of the backup copies, restoration of backups, extent and frequency of backups (based on business requirements, security requirements, and continued operational criticality, backup location for disaster recovery impacts), and backup facility adequacy.
- 1.5.15 Requirements must be implemented to facilitate periodic backup media testing to validate completeness, accuracy, and timeliness requirements consistent with contractual, legal, environmental, and business requirements.
- 1.5.16 Requirements must be implemented for encrypted protection of backups consistent with contractual, legal, environmental, and business requirements.
- 1.5.17 Requirements must be implemented to facilitate monitoring of the execution of backups and addressing failures of scheduled backups to ensure completeness of backups.

1.6 Human Resources Security

Policies and requirements must be implemented to promote the recruitment of competent, qualified individuals, ensuring the organization and user's responsibilities within the context of information security are communicated and accepted in accordance with the Siemens Industry Software (SISW) SaaS Information Security Human Resources Policy.

- 1.6.1 Processes must be implemented for the screening of candidates for employment in accordance with relevant laws, regulations, and ethics. Implemented processes for screening are commensurate with business requirements and the classification of the information resources to be accessed.
- 1.6.2 Processes must be implemented to ensure candidates are made aware of the terms and conditions of employment, during the screening process, employment, and following employment. These processes ensure candidates are made aware of SISW information resource security responsibilities and user security responsibilities.
- 1.6.3 Organizational structures must be established and define lines of reporting.
- 1.6.4 A formal disciplinary action process must be implemented and established.
- 1.6.5 Awareness education and training must be provided and regular updates in organizational policies and requirements, as relevant for their job function are communicated to SISW personnel.
- 1.6.6 Processes must be implemented for the creation, review, approval, and communication of an established policy on information security which acts as the foundation of the security awareness program.
- 1.6.7 Processes must be implemented to ensure employees read and acknowledge their understanding of SISW's established policy on information security annually, including SISW personnel roles and responsibilities relating to information security.
- 1.6.8 Processes must be implemented for the termination of employment in accordance with relevant contractual, legal, environmental, and business requirements.
- 1.6.9 Periodic security training that is adequate to advise SISW personnel on information security best practices must be conducted, including those specific to SISW.
- 1.6.10 Processes must be implemented for the collection, review, and actioning of metrics relating to SISW personnel participation in security awareness program activities.
- 1.6.11 An acceptable use of information resources consistent with information resource classification guidelines and related information security requirements is required.

- 1.6.12 Processes must be implemented for the creation, review, approval and communication of an established policy on acceptable use.
- 1.6.13 Processes must be implemented to ensure SISW personnel read and acknowledge their understanding of the established policy on acceptable use annually, including SISW personnel roles and responsibilities relating to use of information resources.

1.7 Incident Management

Information security incidents must be managed, including detection, analysis, resolution, and lessons learned in accordance with the Siemens Industry Software (SISW) SaaS Incident Management Policy.

- 1.7.1 Formal documented policies and requirements must be implemented to facilitate incident response planning and preparation, monitoring, detecting, analyzing, and reporting information security events and incidents, logging incident management activities, assessment of and decision on information security events / assessment of information security weaknesses, response requirements including those for escalation, controlled recovery from an incident, and communication to internal and external people or organizations.
- 1.7.2 Formal reporting requirements must be implemented to facilitate consistent reporting actions when information security events occur.
- 1.7.3 Formal disciplinary processes must be implemented for dealing with employees who commit security breaches.
- 1.7.4 Formal feedback processes must be implemented to ensure that those persons reporting information security events must be notified of results after the issue has been resolved and closed.
- 1.7.5 Processes must be implemented to ensure the objectives for information security incident management are agreed with by management.
- 1.7.6 Processes must be implemented that communicate organizational priorities for handling information security incidents to employees with incident response obligations.

1.8 Information Resource Management

Information resources must be securely managed by identification, inventorying, maintenance, and protection controls in accordance with the Siemens Industry Software (SISW) SaaS Information Resource Management Policy.

- 1.8.1 Requirements must be implemented that facilitate the tracking of information resources as part of an asset inventory.
- 1.8.2 Requirements must be implemented that facilitate the definition assignment of ownership of information resources.
- 1.8.3 Requirements must be implemented that facilitate the standards for the acceptable use of information resources in accordance with an established policy on human resources security.
- 1.8.4 Standards must be established for the return of information resources upon termination of employment, contract or agreement.
- 1.8.5 Standards must be established for the classification, labeling, and handling of information resources.
- 1.8.6 Requirements must be established for the management of removable media in accordance with the classification standards.
- 1.8.7 Requirements must be implemented to facilitate defining data retention, decommissioning, and disposal protection requirements consistent with contractual, legal, environmental, and business requirements.
- 1.8.8 Mobile devices that are owned and operated by employees in the course of business must be protected (i.e., bring-your-own-device (BYOD) devices) from theft and unintended use by establishing end user agreements with personnel and measures to separate SISW data from personal data on such devices.
- 1.8.9 Processes must be implemented for the management of BYOD devices that access SISW information resources.
- 1.8.10 Processes must be established for the information security management of end point devices and removable media.
- 1.8.11 Processes and procedures must be established to facilitate the installation of software by SISW employees and contractors under controlled circumstances.

1.9 Information Security Risk Management

Information security, personnel and business risks related to information resources must be identified, assessed, and managed in accordance with the Siemens Industry Software (SISW) SaaS Information Security Risk Management Policy.

- 1.9.1 An Information Security Council (ISC) is established to facilitate the development, review, and approval of requirements for the performance of risk assessment activities utilizing defined risk management frameworks.

- 1.9.2 Formal risk assessment requirements must be defined that facilitate the consideration of security risks inherent to the organization, defining of risk tolerance levels, establishing risk treatment measures, and identification of residual risks.
- 1.9.3 An information security council team is established to facilitate the development of risk treatment plan to mitigate risks that have not been otherwise accepted or avoided as a result of risk assessment requirements.
- 1.9.4 Requirements must be established to facilitate execution of periodic risk assessments, generation of risk treatment measures, and periodic monitoring of risk treatment measures for effectiveness.
- 1.9.5 Projects must consider information security as part of their project management methodology to ensure that information security risks are identified, documented and addressed as part of a project when applicable.
- 1.9.6 The organization should leverage special interest groups/professional associations to gain insights into information security threats/vulnerabilities landscape that may contribute to the improvement of the organization's risk posture.

1.10 Logging and Monitoring

Information resource logs must be managed, and security events must be monitored in accordance with the Siemens Industry Software (SISW) SaaS Security Logging and Monitoring Policy.

- 1.10.1 Processes must be implemented for determining the log information to capture from applicable information resources.
- 1.10.2 Processes must be implemented for defining and categorizing security events utilizing a risk-based approach to assess the likelihood and impact of security events on information resources.
- 1.10.3 Standards detailing the required logging capabilities must be implemented to be enabled on information resources to facilitate monitoring and actioning of identified security events.
- 1.10.4 Standards must be established to facilitate retention and disposal of logs consistent with contractual, legal, environmental, and business requirements.
- 1.10.5 Standards defining incident response criteria must be established to facilitate actions required for defined and identified security events in accordance with the Siemens Industry Software (SISW) SaaS Incident Management Policy.
- 1.10.6 Administrative and technical controls must be implemented to restrict access to audit logging facilities and the associated logs.
- 1.10.7 All systems and applications must be continuously synchronized with a trusted time server to ensure consistency of timestamps amongst information resource logs from all in-scope systems or applications.

1.11 Network Security

The Siemens SISW network must be protected through a secure network infrastructure, network access controls, and information transfer requirements in accordance with the Siemens Information Software (SISW) SaaS Network Security Policy.

- 1.11.1 Processes must be implemented to ensure information security related requirements relating to network security are included in the requirements for new information systems or enhancements to existing information systems.
- 1.11.2 Standards and the associated technical and administrative networking controls must be implemented to facilitate teleworking.
- 1.11.3 Administrative and technical controls must be implemented to ensure networks are managed and controlled to protect information with SISW information resources.
- 1.11.4 Segmentation in networks must be established to facilitate segregation of information resources consistent with contractual, legal, environmental, and business requirements.
- 1.11.5 Standards and the associated technical and administrative controls must be implemented to facilitate the protection of information passing over public networks should be protected from fraudulent activity, contract dispute, or unauthorized disclosure and modification.
- 1.11.6 Software installation must be restricted on Company operational systems, including mobile devices and laptops, through the implementation of change management and user access management processes and technical controls.
- 1.11.7 Formal documented policies and requirements must be implemented to facilitate governing the installation of software by users.
- 1.11.8 Standards must be established to guide personnel on the types of software installations that are permitted and what types of installations are prohibited on information resources.

- 1.11.9 Endpoints must be protected by security hardening, malware protection and host-based monitoring; mobile devices must be protected by defined security controls.
- 1.11.10 Formal standards must be implemented for the hardening of SISW information resources, inclusive of configuration management tools to detect and report configuration nonconformities for automated or manual remediation.
- 1.11.11 Processes must be implemented for monitoring information resources.
- 1.11.12 Administrative and technical controls must be implemented for information resource malware detection and remediation.

1.12 Physical Security

Physical facilities must be protected from unauthorized physical access, environmental threats, damage, and interruption in accordance with the Siemens Industry Software (SISW) SaaS Physical Security Policy.

- 1.12.1 Security perimeter protection mechanisms must be implemented to reduce the risk of unauthorized physical access.
- 1.12.2 Access controls must be implemented to restrict physical access.
- 1.12.3 Environmental protection controls must be implemented to ensure physical locations are protected against external and environmental threats.
- 1.12.4 Continuous monitoring of physical security must be implemented at all in-scope locations.
- 1.12.5 A process must be defined for the removal of physical assets from all in-scope locations.
- 1.12.6 The management of physical access keys must be implemented.

1.13 Secure Software Development Lifecycle

Secure software development practices must be implemented to reduce the risk of software-related vulnerabilities residing on information resources in accordance with the Siemens Industry Software (SISW) SaaS Secure Development Policy.

- 1.13.1 Security must be incorporated into all phases of the software development lifecycle.
- 1.13.2 Source code must be maintained within secured and approved repositories.
- 1.13.3 Training regarding secure architecture and engineering principles must be provided to software developers.
- 1.13.4 Requirements for secure coding principles must be established to ensure all software is securely developed and security vulnerabilities are minimized.

1.14 Third-Party Supplier Information Security

Information security risks associated with third party suppliers, inclusive of Information Communication Technology (ICT) and cloud service providers (CSP), who access SISW information resources must be identified, assessed, and managed in accordance with the Siemens Industry Software (SISW) SaaS Supplier Relationship Policy.

- 1.14.1 Information security requirements must be documented and implemented to facilitate the selection of third-party providers.
- 1.14.2 Contracts with third-party providers must be signed and include information security and privacy clauses.
- 1.14.3 Products and services of third-party providers must be used in accordance with information security policies.
- 1.14.4 Information security reviews of existing third-party providers must be periodically performed.
- 1.14.5 Termination of third-party providers or services must comply with information security and privacy clauses defined in signed contracts.
- 1.14.6 Information security requirements shall be determined and applied across all ICT services. Where applicable, SISW shall require that ICT suppliers disseminate the security requirements and practices through the supply chain.
- 1.14.7 A Business impact analysis (BIA) must include continuity considerations during a disruption to ICT services in accordance with the Siemens Industry Software (SISW) SaaS Business Continuity Management Policy.
- 1.14.8 SISW must determine the specific criteria for selecting, using, managing, and changing cloud service providers for providing any or all parts of the services; particularly considerations must be applied for the storage and processing of client information, including personal information, as part of the services.

1.15 Vulnerability Management

Information resources must be maintained by identifying and remediating associated vulnerabilities in accordance with the Siemens Industry Software (SISW) SaaS Vulnerability and Patch Management Policy.

- 1.15.1 A program to review alerts and advisories must be in place to facilitate the identification and communication of threats to information resources.
- 1.15.2 Information resource scans and penetrations tests must be performed in accordance with the Siemens Industry Software (SISW) SaaS Vulnerability and Patch Management Policy.
- 1.15.3 A patch management program is in place to ensure security vulnerabilities applicable to information resources are identified, validated, and approved for implementation to information resources.
- 1.15.4 Contact with special interest groups, forums, and subscriptions must be maintained to remain informed on new and emerging security threats and vulnerabilities.

SISW SaaS Information Security Risk Management Policy requirements

1.1. Information Security Risk Assessment

- 1.1.1. Information security management identifies control and risk owners with insight into and governance over risk areas.
- 1.1.2. Information security management, in conjunction with control and risk owners, develops a security risk assessment process that can be applied consistently, valid, and comparable results.
- 1.1.3. The risk assessment process includes an assessment of inherent risks, including the likelihood and impact for a loss of confidentiality, integrity, availability and privacy of information and systems to the business.
- 1.1.4. The risk assessment process results in the identification of information security risks to organizational operations (including mission, functions, image, or reputation), organizational assets, and individuals, resulting from the operation of organizational systems and the associated processing, storage, or transmission of sensitive and/or critical data.
- 1.1.5. The risk assessment process results in the development of risk acceptance criteria, including the definition of risk tolerance levels.
- 1.1.6. The risk assessment process prioritizes and documents risk treatment activities.
- 1.1.7. The risk assessment process results in the identification of residual risks and actions taken regarding residual risk.
- 1.1.8. The risk assessment process includes monitoring procedures over risk treatment activities (refer to section 1.3 below).
- 1.1.9. Risk assessment activities follow a risk management framework as a guideline for risk assessment activities.

1.2. Security Risk Treatment

- 1.2.1. Information security management establishes a process for analyzing and categorizing the nature and level of risks.
- 1.2.2. Risk treatment methods are established based on risk analysis and categorization and exclude risks to be accepted or avoided based on risk tolerance criteria, as determined through the risk assessment process.
- 1.2.3. Risk treatment, avoidance, and acceptance decisions are documented.

1.3. Risk Monitoring and Reporting

- 1.3.1. Risk assessment procedures are performed on a periodic basis defined by management to assess existing risks and to identify new risks.
- 1.3.2. Metrics for security risk management are defined, collected, analyzed, developed, and periodically reported to management.
- 1.3.3. The information security management team plans, implements, and controls security risk management processes and determines the frequency for monitoring and reporting on risks.

SISW SaaS Internal Information Security Audit Policy requirements

1.1. Roles and responsibilities in connection with ISMS audits shall be detailed in the ISMS Audit Plan and include detailed responsibilities, at a minimum for the following groups:

- Information Security Council
- Lead Auditor
- ISMS Audit Team
- ISMS Management or appointed oversight group

1.2. An ISMS Audit Plan shall be documented that includes the following topics of focus relating to the ISMS Audit:

- Planning and Preparing the ISMS Audit

- Pre-ISMS Audit Meeting
- Opening Meeting
- ISMS Audit Execution
- ISMS Audit Reporting
- Closing Meeting
- ISMS Audit Follow-up and Closure
- ISMS Audit control and site sampling
- Lead Auditor and ISMS Team requirements, skills, and qualification
- ISMS Audit records and outputs
- Procedures related to ISMS Audit Plan revisions and exceptions
- Audit Schedule

SISW SaaS Network Security Policy requirements

1.1. Processes must be implemented to ensure information security related requirements relating to network security are included in the requirements for new information systems or enhancements to existing information systems.

1.2. Standards and the associated technical and administrative networking controls must be implemented to facilitate teleworking.

1.3. Administrative and technical controls must be implemented to ensure networks are managed and controlled to protect information within SISW information resources.

- 1.3.1. Data transferred from information resources on the SISW network must be protected in accordance with the established requirements on data privacy and information security.
- 1.3.2. Standards and the associated technical and administrative controls must be implemented to facilitate access, authentication, authorization and management of network devices and network services.

1.4. Segmentation in networks must be established to facilitate segregation of information resources consistent with contractual, legal, environmental, and business requirements.

- 1.4.1. Physical and logical network segmentation must be established to facilitate segregation of information resources consistent with contractual, legal, environmental, and business requirements.
- 1.4.2. By default, network connections must be configured in such a way to deny traffic unless it is explicitly allowed for a necessary purpose.
- 1.4.3. Network security architecture must be documented (e.g., via network diagram) and periodically reviewed and updated for revisions.
- 1.4.4. Network security configurations, rules and permissions established within network devices (e.g., Firewalls, WAF), virtual environment gateways (e.g., Load Balancer, Security Groups, Transit gateway) or other configurable element(s) (e.g., IP tables, endpoint firewalls) must be reviewed at least annually, and results of the review documented and approved by the asset owner.
- 1.4.5. Redundancies in network communication must be established to manage outages in accordance with an established policy on business continuity management.
- 1.4.6. SI SW must maintain segregation between internal and customer accessible environment
- 1.4.7. Segregation of tenants in a multi-tenant customer accessible environment must be enforced via the implementation of appropriate controls as a minimum, at the:

- Application Layer
- Network Layer
- Data handling
- Data at rest layer

1.5. Standards and the associated technical and administrative controls must be implemented to facilitate the protection of information passing over public networks from fraudulent activity, contract dispute, or unauthorized disclosure and modification.

- 1.5.1. Administrative and technical controls must be implemented to ensure the SISW network is managed and controlled in a way that protects information resources transferred across the network.
- 1.5.2. Technical controls must be implemented to protect wireless access, including but not limited to established authentication protocols, ensuring authorized access, encryption techniques, default keys, network filtering, and monitoring for rogue access points.

- 1.5.3. Wireless security mechanisms must facilitate the protection of information passing over public networks, including protections against fraudulent activity or unauthorized disclosure and modification of information resources.
- 1.5.4. Where applicable, control and monitor the use of Voice over Internet Protocol (VoIP) technologies.
- 1.5.5. Remote connections into the SISW network, including employee or third-party access, must be established through approved methods (e.g. Secure Shell (SSH), virtual private network (VPN), multi-factor authentication (MFA)).
- 1.5.6. Third-party access to the SISW network must be restricted and only enabled based on legitimate business need.
- 1.5.7. Network time protocols must be supported by SISW network infrastructure to support time reference / synchronization for assets and protect the network from temporal attacks. (i.e. network clocks must be synchronized)

1.6. Formal documented policies and requirements must be implemented to facilitate governing the installation of software/firmware by network administrators.

- 1.6.1. Technical controls must be implemented to restrict the installation of software/firmware on operational systems.

1.7. Standards must be established to guide personnel on the types of software installations that are permitted and what types of installations are prohibited on information resources.

- 1.7.1. Requirements must be implemented to govern the installation of software by personnel and establish the types of software installations permitted and prohibited on information resources.
- 1.7.2. Applications or specific application versions no longer supported by the vendor or whose development has been discontinued must not be used and be removed from IT systems.

1.8. Formal standards must be implemented for the hardening of SISW information resources, inclusive of configuration management tools to detect and report configuration nonconformities for automated or manual remediation.

- 1.8.1. Endpoints must be configured, hardened, monitored, and maintained based on established security requirements, including but not limited to installation of only approved images during initial configuration, restrictions on local administrator privileges, periodic patch updates, and operating system hardening to provide only necessary ports, services and protocols.
- 1.8.2. All mobile devices must be deployed with hardening standards, in line with documented procedures.

1.9. Processes must be implemented for monitoring information resources.

- 1.9.1. Network activities must be logged and monitored, considering the requirements established in SISW's policy on security logging and monitoring.
- 1.9.2. Connections from the SISW network to systems external to the SISW network must be verified and controlled.

1.10. Administrative and technical controls must be implemented for information resource malware detection and remediation.

- 1.10.1. Access points into the SISW network from internal and external connections must be secured using network protection and detection devices, including but not be limited to firewalls, routers, switches, intrusion detection / prevention systems, and data loss prevention systems.
- 1.10.2. Administrative and technical controls must be implemented for information resource malware detection and remediation.
- 1.10.3. Web filtering rules must be established and kept current to minimize exposure to known or suspected malicious online resources.
- 1.10.4. Host-based protection mechanisms (e.g. firewalls) must be configured for endpoints.

SISW SaaS Physical Security Policy requirements

1.1. Facilities department is responsible for assessing Siemens's physical locations and applying physical security measures and adjusting those measures on an ongoing basis.

- 1.1.1. SISW personnel are not permitted to adjust or circumvent physical security mechanisms (e.g., card readers, cameras, etc.), without written approval from Facilities.
- 1.1.2. Questions, concerns, or change requests regarding physical security measures must be directed to Siemens' Facilities team.

1.2. Perimeter security mechanisms must be implemented to reduce the risk of unauthorized physical access.

1.2.1. Perimeter security mechanisms (e.g., cameras, alarms, security guards, etc.) must be implemented, as appropriate, for continuous monitoring to protect information resources, Siemens personnel, assets, and data at physical locations.

1.3. Access controls must be implemented to restrict physical access.

1.3.1. Physical access control mechanisms (e.g., identification badges, controlled reception, cameras, access logging, etc.) must be implemented at office buildings, data centers, and other locations.

1.3.2. Access to physical locations must be restricted only to Siemens personnel who require access.

1.3.3. Visitor access control mechanisms (e.g., visitor logs, escort requirements, etc.) must be defined and implemented commensurate with the sensitivity of the physical location.

1.3.4. At a minimum, Siemens staff must supervise the maintenance activities of maintenance personnel without required access authorization and escort guests.

1.3.5. Physical keys that are used to secure rooms, datacenters, or similar areas must be inventoried and a periodic review of those physical keys must be conducted.

1.3.6. Physical keys used to secure cabinets and drawers must be inventoried.

1.3.7. Employees must report lost, stolen, or damaged keys to the appropriate manager in a timely manner.

1.3.8. Reviews of access to sensitive physical locations must be performed periodically.

1.3.9. The organization must define the requirements for the removal of physical assets, including when the removal must be logged. When the removal is logged, it must include the type of asset being removed, individual that is responsible for the asset upon removal, and the approving authority.

1.3.10. Access must be revoked upon termination or change of employment.

1.3.11. Delivery and loading areas must be segregated from internal secure areas.

1.4. Environmental protection controls must be implemented to help ensure physical locations are protected against external and environmental threats.

1.4.1. Environmental control mechanisms must be implemented at physical locations. Environmental control mechanisms may include heating, ventilation, and air conditioning (HVAC), water drainage, fire suppression, emergency lighting, power distribution unit (PDU) implementation, continuous power, humidity control, etc.

1.4.2. Access to alter environmental control mechanisms must be restricted to authorized personnel.

1.4.3. Cables within the office, storage IT closets, and datacenters shall be protected from damage or interference with considerations for environmental impact which may include but is not limited to flooding.

1.4.4. Equipment maintenance should follow a defined service schedule. Prior to scheduled maintenance, where possible, any confidential information should be cleared from the equipment.

1.5. Monitoring of physical security and environmental-related incidents must be implemented.

1.5.1. The effectiveness of perimeter security and access control mechanisms, as well as environmental controls, must be continuously monitored and periodically evaluated.

1.5.2. Data from access control and video surveillance mechanisms (e.g., access logs, video recordings, etc.) must be retained in accordance with defined retention schedules.

1.5.3. Physical and environmental security incidents must be monitored and responded to in accordance with an established incident management policy and incident response plans.

1.6. Remote work sites (such as working from home) must have appropriate physical protection mechanisms in place and meet the requirements of the SISW Company Directives based on the classification of data accessed or stored by an employee in that remote work site.

SISW SaaS Secure Development Policy requirements

1.1. Security must be incorporated into all phases of the software and services development lifecycle.

1.1.1. Secure software and services development processes must be established and implemented to facilitate the assessment of security risks and requirements during development.

1.1.1.1. Secure development processes must include risk modeling, such as threat modeling, attack modeling, or attack surface mapping to help assess the security risk for the software

1.1.1.2. Where possible, secure development processes must be defined to ensure that the necessary information to support security evaluation criteria are effectively gathered. Automation is recommended.

- 1.1.2. Roles and responsibilities must be defined for all facets of software and services development and must be updated as needed to reflect current practices.
- 1.1.3. Data must be handled in accordance with the Data Classification, Handling, and Sharing Policy throughout all phases of the development lifecycle.
- 1.1.4. Privacy and security impact assessments must be performed for new and significantly updated application software and services.
- 1.1.4.1. Associated security requirements, risks statements, risk response measures, and design decisions must be tracked and maintained
- 1.1.5. Prior to inclusion, the impact of third-party dependencies such as libraries, snippets, run-times should be evaluated from both security and terms of use/licensing and monetization perspectives, as defined by the Compliance and Legal functions.
- 1.1.6. Security requirements for all third party components used, or sought out for use, in developed software must be defined and communicated to third parties. These requirements must be validated both prior to, and during, utilization of the code or component. Considerations must include:
- Core security requirements put into acquisition documents, contracts, and third party agreements
 - Defining requirements for selecting/approving/rejecting software (e.g., third party vulnerability disclosure program), IR capabilities, adherence to Siemens requirements, providing vendor attestation, provide code provenance information
 - Documenting approved exceptions
- 1.1.7. Processes must be in place to identify vulnerabilities during development and after release, including vulnerabilities associated with third-party and open source components.
- 1.1.8. Free and open source software components and libraries must be registered to ensure legal and licensing clearance for applied components and libraries (e.g., Blackduck).
- 1.1.9. Vulnerabilities identified during and after development must be remediated according to criteria defined in the Siemens Industry Software (SISW) SaaS Vulnerability and Patch Management Policy.
- 1.1.10. Code review methodologies must be defined and implemented. Findings from the code review, and follow-up actions, must be recorded.
- 1.1.11. A final review must be performed to verify that security requirements were addressed prior to implementation.
- 1.1.12. Teams must determine whether executable code testing is necessary. If deemed necessary, the types of testing to be used must be defined (e.g., sandbox testing, testing at each stage of development).
- 1.1.13. Production code changes must be performed in accordance with the Siemens Industry Software (SISW) SaaS Change Management Policy. Code changes must be documented and tracked by using a software project management tool (e.g., Polarion, JIRA), and where possible within the code development tool as well (versioning).
- 1.1.14. Where appropriate, support for standardized security features must be built (e.g., enabling integration with existing log management, identity management, access control, or vulnerability management systems).
- 1.1.15. Where in-house-developed tools, tool configurations, customized outsourced components are used, developers must follow all security requirements defined within this policy.

1.2. Source code must be developed and maintained within approved, secured repositories and controlled throughout its lifecycle.

- 1.2.1. Access to all forms of code must be restricted to authorized personnel following the principle of least privilege and the four-eyes principle.
- 1.2.2. Source code repositories must not be cloned or transmitted in clear text.
- 1.2.3. Version control of source code must be maintained.
- 1.2.4. Changes to source code must be logged and monitored.
- 1.2.5. Source code must be archived and secured by mechanisms comparable to production code.
- 1.2.6. Where possible, integrity verification functionality must be utilized for all software and shared with acquirers (e.g., using cryptographic hashes, certificate authorities, periodically reviewing code signing processes).
- 1.2.7. Related security data (e.g., integrity information, provenance data, associated images) must be archived securely for all software.

1.2.8. Provenance data for all components of each software release (e.g., an SBOM), must be collected, safeguarded, maintained, and (as needed) shared with any internal parties or acquirers that must have access to it.

1.3. Secure development training must be provided to programmer analysts and software engineers.

1.3.1. Training regarding common vulnerabilities (e.g., OWASP Top 10) and secure coding methods must be provided to software developers upon hire and as needed thereafter. Periodic evaluations of personnel proficiency and role-based training must be done, and needed updates to training made.

1.3.2. Secure coding guidelines to develop software and services securely must be established and made available.

1.4. Secure system architecture and engineering principles must be developed and implemented for development personnel.

1.4.1. SISW must adhere to the principle of least privilege within the system architecture.

1.4.2. Security must be designed within all architecture layers (front-end and back-end).

1.4.2.1. Security should be considered in a multi-tiered approach spanning assets that may provide for controls within various layers of the stack. Architecture and design must consider security as a holistic goal with control implementation planned to span across all layers.

1.4.3. Development teams should enforce peer code reviews to identify and document potential weaknesses within systems.

1.4.4. Information systems that process and store information must implement end-to-end encryption.

1.4.5. SISW must harden information systems to minimize the exposure to security vulnerabilities.

1.5. Secure coding principles must be developed and implemented for development personnel.

1.5.1. Initial planning and preliminary development requirements and activities must consider:

1.5.1.1. Validating the developers' competencies through the onboarding process and supplemental training. Development teams must enforce the requirements of the defined secure coding principles for all development personnel.

1.5.1.2. The separation of testing and production environments to ensure data is not compromised by any development and testing activities

1.5.1.3. Using the most recent version of development tools to minimize security vulnerabilities

1.5.2. Development activities must incorporate the following requirements:

1.5.2.1. As part of the code review process, developers must make use of system security testing tools to identify erroneous code that may pose a security threat

1.5.2.2. Any vulnerabilities identified through the system security testing must be remediated based on the vulnerability schedule outlined within the Siemens Industry Software (SISW) SaaS Vulnerability and Patch Management Policy

1.5.2.3. Any vulnerability exceptions must be assessed with approval gained from the CISO/management per the processes defined within the SISW SaaS Vulnerability and Patch Management Policy

1.5.2.4. Development teams must prohibit the use of insecure design techniques including but not limited to unapproved code samples

1.5.3. Post development activities must incorporate the following requirements to ensure continuous monitoring of systems:

1.5.3.1. Identify, review, and remediate any potential security incidents or weaknesses

1.5.3.2. Regular review of system logs for anomalous activities

1.5.3.3. Periodic review of access to code repositories to prevent unauthorized access and tampering

1.6. Outsourced developers must adhere to and acknowledge SISW's Secure Development Policy inclusive of Secure System Architecture and Engineering Principles, and Secure Coding Principles.

1.6.1. Where possible, SISW should consider security awareness training inclusive of secure development training for outsourced developers.

1.7. Secure development, testing, and operational environments must be separated to reduce the risks of unauthorized access or changes to the operational environment.

1.7.1. Product, team, environment, or technology-specific hardening and maintenance requirements must be defined for all development operations groups. Considerations should include:

1.7.1.1. Development endpoint requirements, review/update software development infrastructure/process requirements annually, educate developers on pending changes

1.7.2. Teams must specify which tools or tool types must be included in developer toolchains to mitigate risk, as well as how the toolchain components are integrated. Tools used must follow recommended security practices for deployment, operation and maintenance, including newly added tools.

1.7.3. Build tools, such as compilers or interpreters, must have standard configurations defined, be kept up-to-date, and have all changes tracked.

1.8. Upper management or an authorizing official must provide commitment to secure development responsibilities for all development teams.

1.9. Upon identification of any root causes of any issues or vulnerabilities arising during any point in the software or service lifecycle, teams must revise any of the above processes and record lessons learned or revisions to the processes.

SISW SaaS Security Logging and Monitoring Policy requirements

1.1. Information resources must be configured to log system and security events.

1.1.1. Security logging standards must be established and implemented for information resources considering security and compliance requirements, including SISW's information security objectives and metrics.

1.1.2. Creation of customer accessible log data must be isolated by customer

1.1.3. The following events should be considered for logging:

- Modification of system access rights (e.g., adding a new user or group, changing user privilege levels, changing file permissions, etc.)
- Information resource process startup, restart, shutdown, failure, or abnormal end
- User and system activities, including successful and failed attempts to access information resources and data, elevation of privileges, application transaction records, and cryptographic failures
- Creation and deletion of system-level objects (e.g., executables, configuration files, applications, or system files)
- Actions taken by individuals or service accounts with root or administrative privileges
- Anomalous activity (e.g., unauthorized access to a resource) detected by security tools (e.g., Intrusion Detection Systems)
- Activation and deactivation of security tools (e.g., anti-malware)
- Initialization, stopping, or pausing of logs
- Successful and unsuccessful logins to cloud management interfaces
- Activities done through the cloud management interface
- Access to cloud assets routed through e.g. SSH, RDP or HTTPS
- Management of user accounts in the cloud environment
- Key Management Services (KMS) operated in the cloud e.g. encryption key revocation
- Changes to Access Control Lists (ACL) or firewall rules that manage the access to the assets in the cloud environment
- Successful and unsuccessful logins and activities of user accounts with full privileges on the cloud environment (e.g., root accounts)
- SDLC lifecycle, deployment of code to production environment(s) e.g. user, code version, date, time

1.1.4. The following details must be captured in logs:

- Type of action
- Identifiers for the subject requesting the action (e.g., username, machine name, IP address, etc.)
- Identifiers for the object the action was performed on (e.g., file name, unique record identifier, etc.)
- Date and time the action was performed, including relevant time-zone information if not in Coordinated Universal Time
- Indication of success or failure of the action

1.1.5. Captured logs must be sufficient to detect and reconstruct security-related events for investigation and forensics purposes.

1.1.6. Log information and meta data must be classified and labelled in accordance with the SISW SaaS Data Classification, Handling, and Sharing Policy.

1.1.7. Periodically, the details to be captured in logs must be reviewed for any needed additions, removals, or adjustments based on Siemens activity.

1.2. Logs must be monitored and analyzed to detect unusual activity that may indicate compromise.

1.2.1. Processes for monitoring and reviewing logs and alerts must be established and implemented to detect and respond to anomalous events and activities, including logging failures.

1.2.2. A central log collection service should be considered to aggregate and correlate log events for triage and response, and to enable on-demand log report generation.

1.2.3. Where warranted and applicable, responses to detected security events must follow Siemens's Incident Response Plan and Data Breach Response Plan, in accordance with the SISW SaaS Incident Management Policy.

1.2.4. Configuration logs shall be continuously monitored to verify configuration settings and activities performed.

1.3. Service Monitoring information shall be made accessible to cloud service customers.

1.3.1. Customers shall have the ability to monitor service availability and track the status of any incidents.

1.4. The integrity of log records must be maintained to facilitate successful analysis and investigation.

1.4.1. Logs must be protected from unauthorized modification or deletion.

1.4.1.1. Automatically created alerts must be generated upon modification or deletion of logged data for taking actions.

1.4.2. Access to logs must be restricted based on job responsibilities and the principle of least privilege, in accordance with the Siemens Industry Software (SISW) SaaS Access Control Policy.

1.4.3. Logs must be retained in a logically isolated location or environment

1.4.4. Clocks of information processing systems being monitored must be synchronized to ensure the accuracy of log data output.

1.4.5. Security relevant logs with security incidents shall be retained until 6 months past incident resolution unless otherwise required by law or business reason.

1.4.6. Security relevant logs without security incidents shall be retained for a minimum of 180 days.

1.4.7. All logs without security incidents containing PII shall be retained for a maximum of 6 months.

1.4.8. All other logs shall be retained for a minimum of 30 days unless otherwise required by law or for business reason.

1.4.8.1. Logs relevant to monetization will be retained in accordance with the requirements of P-LAW-14 for financial records.

SISW SaaS Supplier Relationship Policy requirements

1.1. Identification of all Supplier Relationships

1.1.1. All supplier services must be identified and categorized according to supplier type, significance and criticality. This identification and categorization process should include any information communications technology (ICT) capability and/or cloud service provider (CSP) and should be established prior to vendor selection.

1.1.2. Formal documentation of technical and organizational relationships must be maintained, covering the roles, responsibilities and credentials of representatives of these suppliers.

1.2. Supplier Selection

1.2.1 All third-party service providers must go through a risk assessment prior to purchasing. The purpose of this assessment is to determine the third-party's impact on the confidentiality, integrity, and availability of Company data and processes, and determine whether the risk associated with using the vendor, service or product is acceptable to the Company.

1.2.2 SISW must determine criteria for selecting cloud service providers that provides considerations for:

- Merit of cloud service versus on-premises solutions
- Cloud specific security certifications or controls that the provider can attest to
- Compatibility with existing SISW cloud and non-cloud products and tools
- Availability and latency across distributed geographical locations
- Response and transparency for security related events

- Portability and flexibility to migrate to other solutions as needed
- Solvency and continued support for evolving technology

1.2.3 Vendors or service providers that access, process, transmit, or store data that has confidentiality, integrity, and availability requirements must agree to the Company's security requirements or demonstrate equitable controls.

1.2.3.1 SISW should identify alternate suppliers to mitigate the risk of an ICT supplier disruption, outage, or insolvency

1.2.4 Supplier reviews must be completed prior to onboarding and at least annually leveraging the Third Party Evaluation template to review the risk and possible impact from the use of a third party product / deliverable

1.2.4.1 Completed supplier reviews must have a corresponding supplier evaluation scorecard to be used as a baseline for highlighting potential risks to confidentiality, integrity, and availability

1.2.4.2 Suppliers will demonstrate third party certifications or assessments against one or both of ISO 27001 or SOC2 Type II

1.2.4.2.1 Suppliers that cannot demonstrate third party certifications or assessments against neither of ISO 27001 nor SOC2 Type II, shall be subject to a SISW-conducted assessment

1.2.4.2.2 The SISW assessment shall be based on the ISMS protection concepts to ensure Confidentiality, Integrity and Availability evaluating the controls in 1.2.4.3.

1.2.4.2.3 The assessment, identified risks and their mitigation must be reviewed and approved by the Head, Information Security Management & Quality Management or delegate

1.2.4.3 Review of the third-party certifications, attestations, or any assessments must, at minimum, include evaluation of policy alignment with SISW in the following areas:

- Human Resources
- Information Security and Privacy Program Management
- Security Operations
 - Vulnerability Scanning
 - Policy/Process/Procedure
- Secure Development
- Supplier Risk Management
- Incident Response
 - Breach notification
- Availability
 - DR (MTD, RPO, RTO)
 - SLAs
- Penetration Testing

1.3. Supplier Relationship Management

1.3.1 Supplier relationship owners for each supplier must be identified.

1.3.2 Relationship owners must liaise on customer or supplier issues and ensure the quality of the relationship is based on trust & transparency (e.g., through service level agreements).

1.3.3 SISW must consider how to change or stop the use of cloud services, if needed.

1.4 Supplier Risk Management

1.4.1 Contracts must conform to legal and regulatory requirements and must clearly state service goals and expected deliverables.

1.4.2 Risks relating to suppliers' ability to continue effective service delivery to SISW in a secure and efficient manner on an ongoing basis must be identified and mitigated.

1.4.3 Through the application of risk management disciplines, SISW must further consider non-disclosure agreements (NDAs), escrow contracts, and continued supplier viability, conformance with security requirements, alternative suppliers, penalties and rewards.

1.5 Supplier Service Delivery

1.5.1 A process to monitor service delivery must be established to ensure the supplier is meeting SISW's current business requirements and is continuing to adhere to the contract agreements and service level agreements.

1.5.2 This process must also help ensure that performance is competitive with alternative suppliers and in market conditions.

1.5.3 This process must also consider changes to the provision of services by suppliers, including maintaining and improving existing information security policies, procedures and controls, taking account of the criticality of business information, systems and processes involved and re-assessment of risks.

1.6 Use of Information Communication Technology (ICT), technological tools and resources used for the gathering, storing, transmitting, retrieving, or processing of information

1.6.1 Information security requirements shall be determined and applied across all ICT services. Where applicable, SISW shall require that ICT suppliers disseminate the security requirements and practices through the supply chain.

1.6.2 SISW shall define requirements for handling and sharing information through the ICT supply chain in accordance with the Data Classification, Handling, and Sharing Policy. Additionally, SISW shall require suppliers to communicate any potential issues and compromises that may affect the organization or supply chain.

SISW SaaS Vulnerability and Patch Management Policy requirements

1.1. Vulnerability and patch management standards must be established for each type of information resource.

1.1.1. The vulnerability and patch management process includes the following points of focus:

- Severity ratings and associated service level agreements (SLAs)
- External and internal vulnerability scanning criteria
- Vulnerability Analysis and Root Cause analysis
- Communication methods and frequencies
- Prioritization and response criteria
- Vulnerability remediation and patch implementation tracking mechanisms
- Vulnerability and patch management exceptions process
- Mechanisms to obtain vulnerability and patch data from applicable and trustworthy information resource vendors

1.1.1.1. Security fix for components implemented must be obtained from a trustworthy source, for example: website of the vendor with https, download link in the security fix bulletin, or internal distribution server for patches (e.g. WSUS)

1.1.2. Severity ratings and associated SLAs of vulnerabilities and patches must include the following categories:

- Critical (e.g., Easily exploitable by a remote unauthenticated attacker, Common Vulnerability Scoring System (CVSS) score 9.0 and 10.0, 30 day remediation)
- High (e.g., Unauthenticated users can view data that should require authentication, local users can elevate privilege, CVSS score between 7.0 and 8.9, 60 day remediation)
- Medium (e.g., Difficult to exploit, CVSS score between 4.0 and 6.9, 90 day remediation)
- Low (e.g., Minimal security impact, CVSS score between 3.9 and 0.1, 180 day remediation)
- Informational (e.g., information only, no security impact, CVSS score equal to 0.0, no remediation commitment)

1.1.3. The external and internal vulnerability scanning criteria must include processes for:

- Running discovery scans to identify new information resources at least weekly
- Performing scheduled scans for critical and non-critical information resources at least monthly and quarterly, respectively
- Scanning information resources upon significant changes to the environment and on an ad-hoc basis, as requested
- Timing scans according to patch release cycles of applicable vendor products

1.1.4. Vulnerabilities must be analyzed prior to implementing risk response measures to validate impact, risk level, and appropriateness of response measure.

1.1.5. Periodically, root cause analyses and recurring vulnerability cause evaluation must be done.

1.1.6. The results of root cause analyses will be used to assess all other similar software and IT products to proactively remediate any similar root causes.

1.1.7. At a minimum, prioritization and response criteria for vulnerability remediation and patch implementation must account for:

- Regulatory requirements
- Criticality of information resources
- Severity ratings

1.2. Vulnerability notification service must be implemented.

- 1.2.1. Software applications, components and software libraries must be registered in SVM (Siemens Vulnerability Monitoring Tool) to receive vulnerability notifications and triggers for fixing cloud environment vulnerabilities.
- 1.2.2. For software applications, components or software libraries which are not available in SVM Tool, a request to add it must be placed.
- 1.2.3. A vulnerability disclosure program must be established to share applicable critical information with customers.

1.3. Vulnerability scans and penetration tests must be performed periodically.

- 1.3.1. Internal and external vulnerability scans must be performed on all information resources according to the defined scanning criteria.
- 1.3.2. External scans of any PCI environments must be validated by an Approved Scanning Vendor (ASV) on an annual basis.
- 1.3.3. Rescans must be performed if "critical" or "high" vulnerabilities classified are identified and are subsequently remediated.
- 1.3.4. Internal Information resources (not exposed to public access/internet) must be selected for penetration testing based on the outcome of their Protection Concept evaluation.
 - 1.3.4.1. The selection process for assets to be included for penetration testing must also define the frequency of the testing.
 - 1.3.4.2. Penetration tests for information assets not exposed to the internet must be performed at the defined frequency and upon significant changes to the architecture.
- 1.3.5. Penetration tests of information assets exposed to the internet must be performed at least annually and upon significant changes to the network or architecture.
 - 1.3.5.1. Where information assets are exposed to the internet and process customer data, penetration tests must be performed by an independent 3rd party approved by the CISO.
 - 1.3.5.2. During the initial launch of information assets exposed to the internet that process customer data, a penetration test must be performed within 30 days.
 - 1.3.5.3. The approved independent vendors for performing penetration tests include Booz Allen, Coalfire, iVision, Optiv.
- 1.3.6. A penetration re-test must be performed if a "critical" or "high" severity risk compromise for an attack scenario is identified and subsequently remediated.
- 1.3.7. Penetration tests must be performed according to an established penetration testing methodology that considers:
 - Coverage of the environment and other critical information resources
 - Testing from outside and inside of the network
 - Validation of segmentation controls
 - Application and network layer testing requirements
 - Consideration of previously experienced threats and vulnerabilities
 - Retention requirements for testing results and remediation activities
- 1.3.8. Personnel performing vulnerability scans and penetration tests must be organizationally independent from personnel performing system administration activities.

1.4. Vulnerability remediation and patch implementation must be performed within defined timelines.

- 1.4.1. Identified vulnerabilities and patches must be managed by the Asset Manager based on the guidelines in this policy.
- 1.4.2. Patches must be implemented according to the Change Management Policy.
- 1.4.3. Vendor-released patches with severity ratings of "critical" and "high" must be implemented within 30 and 60 days, respectively.

1.5. Exceptions to vulnerability and patch management must be reviewed and approved.

- 1.5.1. Exceptions process for vulnerability and patch management must define processes for documenting and validating false positives for identified vulnerabilities
- 1.5.2. Delayed or deferred actions for the remediation of vulnerabilities and implementation of patches that cannot be addressed within required timelines require risk to be reviewed and approved.
- 1.5.3. "Critical" or "High" vulnerabilities with remediations that are overdue require review and acceptance of risk by the Business Segment Leader.

1.6. Confidentiality of vulnerability and penetration test results must be identified and applied to all relevant artifacts

1.6.1. The artifacts generated as a result of vulnerability scans and penetrations tests should be classified and labelled per the SISW SaaS Data Classification, Handling, and Sharing Policy. Such artifacts should be handled per the labelled data classification level and sufficient confidentiality notices should be generated prior to sharing or distribution.

1.7. Information security threat intelligence must be continually gathered, obtained, evaluated, and integrated into the risk management process.

1.7.1. Contacts with external special interest groups, forums, or subscriptions identifying the latest threats and vulnerabilities must be maintained.

1.7.2. SISW should determine the roles and responsibilities for receiving, analyzing, and prioritizing the response to security threats and risk to the organization.